FIAP ON

LEADERSHIP AND CORPORATE ACCOUNTABILITY

# GERENCIAMENTO DE RISCO

LEANDRO RUBIM

4

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

## LISTA DE FIGURAS

Figura 4.1 – Foguete Saturn 5 ..... 4
Figura 4.2 – Elementos do risco ..... 5
Figura 4.3 – Exemplo Mega-Sena acumulada ..... 6
Figura 4.4 – ABNT ISO Guia 73:2009 ..... 7
Figura 4.5 – Classificação do risco em relação à natureza de seu impacto ..... 8
Figura 4.6 – Dinâmica da gestão de riscos ..... 9
Figura 4.7 – Relacionamentos entre princípios, estrutura e processo da ISO 31000 16
Figura 4.8 – Relacionamentos entre princípios, estrutura e processo da ISO 31000. ..... 17
Figura 4.9 – Relacionamentos entre princípios, estrutura e processo da ISO 31000 19
Figura 4.10 – Componentes da estrutura de gestão de riscos do padrão ISO 31000 ..... 20
Figura 4.11 – Processo de Gestão de Risco do padrão ISO 31000 ..... 23
Figura 4.12 – Mapa de risco ..... 25

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

**SUMÁRIO**

4 GERENCIAMENTO DE RISCO ..... 4
4.1 O que é risco, controle e gerenciamento de risco ..... 4
4.2 Benefícios – por que gerenciamento de riscos? ..... 10
4.3 Como gerenciar riscos – o padrão ISO 31000 ..... 15
4.3.1 Princípios da gestão de riscos ..... 17
4.3.2 Estrutura para gestão de riscos ..... 19
4.3.3 Processo para gestão de riscos ..... 22
4.3.4 Estabelecimento do contexto ..... 23
4.3.5 Análise e avaliação de riscos ..... 24
4.3.6 Tratamento de riscos ..... 26
4.3.7 Monitoramento e análise crítica ..... 27
4.3.8 Comunicação e consulta ..... 28
REFERÊNCIAS ..... 29

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

# 4 GERENCIAMENTO DE RISCO

A esta altura, percebemos que o gerenciamento de riscos é extremamente importante, não só para garantir a saúde financeira da organização e o cumprimento de regulamentações, como também para o sucesso da estratégia.

Arthur Rudolph, cientista que desenvolveu o foguete Saturn 5, que levou a missão Apollo à Lua, explicou bem a abordagem de gerenciamento de risco em seu trabalho:

> "Você deseja uma válvula que não vaze e você tenta tudo o que é possível para desenvolvê-la. Mas, no mundo real, todas as válvulas vazam. Então, você deve determinar quanto vazamento pode ser tolerado." (SAXON, 1996, tradução nossa)

Figura 4.1 – Foguete Saturn 5
Fonte: Google Imagens (2017)

A capacidade de administrar o risco, e com ele, a vontade de correr riscos e de fazer opções ousadas, são elementos-chave da energia que impulsiona o sistema econômico (BERNSTEIN, 1997, p.3).

O gerenciamento de risco se tornou essencial ao progresso e à própria manutenção da humanidade. Por isso, vamos estudá-lo neste capítulo.

## 4.1 O que é risco, controle e gerenciamento de risco

Risco é um conceito abstrato e, embora boa parte das pessoas consiga administrá-lo razoavelmente em sua vida cotidiana, não é simples entender os elementos que o compõem e de sua dinâmica de interação.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Para compreender riscos e poder gerenciá-los adequadamente, é necessário conhecer os componentes do risco (Figura Elementos do risco):

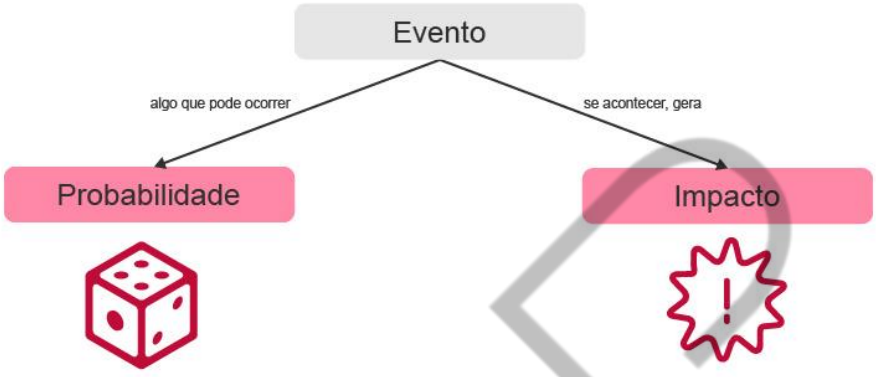


Figura 4.2 – Elementos do risco
Fonte: Elaborado pelo autor (2017)

O primeiro aspecto importante de um risco é que não se trata de acontecimento real, mas de um evento que pode ocorrer em dada circunstância, ou seja, que apresenta uma probabilidade de ocorrência. Essa característica associa a cada risco um grau de incerteza, o que torna sua compreensão mais difícil pelas pessoas.

O segundo aspecto importante de um risco é o efeito potencial derivado de sua ocorrência, ou seja, o impacto gerado pelo evento, caso ele aconteça na realidade. Esse impacto pode ocorrer de várias formas.

Usualmente, os riscos são considerados como eventos potenciais cujo impacto é negativo e, dessa forma, fomenta ações de caráter preventivo. Essa perspectiva pessimista é normalmente adotada por organizações que trabalham com segurança, como a polícia, os bombeiros e as forças armadas. Por exemplo, os agentes do corpo de bombeiros realizam vistorias para autorizar o funcionamento de prédios públicos, que devem possuir, dentre outras coisas, equipamentos de combate a incêndio, equipe de brigadistas treinados para guiar as pessoas em caso de emergência.

No entanto, há riscos cujos possíveis impactos são considerados positivos. Essa perspectiva otimista estimula investimentos de recursos ou esforços para aumentar as chances de ganhos. Por exemplo, quando a Mega-sena está acumulada,

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

um número maior de pessoas faz apostas nesse jogo de loteria. A lógica do apostador de loteria é a mesma do investidor no mercado financeiro, ou seja, se o evento esperado acontecer, ele terá ganhos que compensam os riscos.

Figura 4.3 – Exemplo Mega-Sena acumulada
Fonte: Globo.com (2017)

Como entender riscos é essencial para poder gerenciá-los, tornou-se necessário padronizar os conceitos e as definições sobre o tema, em âmbito mundial. Por isso, a *International Organisation for Standardisation* (ISO) mobilizou seus membros em comissões para a criação de guias e padrões (também denominadas normas no Brasil) relativos a gerenciamento de risco. Eles serão adotados neste capítulo, pois estabelecem um conjunto de conhecimentos, práticas e recomendações que vêm sendo adotados por várias organizações ao redor do mundo.

O *ISO Guide 73 – Risk Management – Vocabulary*, foi editado em 2009 pela ISO e, concomitantemente, foi lançado no Brasil pela Associação Brasileira de Normas Técnicas (ABNT) como ABNT ISO Guia 73:2009 – Gestão de Riscos – Vocabulário. Suas principais definições estão relacionadas a seguir (ABNT, 2009a):

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

**1.1**
**risco**
efeito da incerteza nos objetivos

NOTA 1 Um efeito é um desvio em relação ao esperado – positivo e/ou negativo.

NOTA 2 Os objetivos podem ter diferentes aspectos (tais como metas financeiras, de saúde e segurança e ambientais) e podem aplicar–se em diferentes níveis (tais como estratégico, em toda a organização, de projeto, de produto e de processo).

NOTA 3 O risco é muitas vezes caracterizado pela referência aos **eventos** (3.5.1.3) potenciais e às **consequências** (3.6.1.3), ou uma combinação destes.

NOTA 4 O risco é muitas vezes expresso em termos de uma combinação de consequências de um evento (incluindo mudanças nas circunstâncias) e a **probabilidade** (*likelihood*) (3.6.1.1) de ocorrência associada.

NOTA 5 A incerteza é o estado, mesmo que parcial, da deficiência das informações relacionadas a um evento, sua compreensão, seu conhecimento, sua consequência ou sua probabilidade.

Figura 4.4 – ABNT ISO Guia 73:2009
Fonte: ABNT (2017)

Das definições em destaque, é importante considerar:

**Efeito = consequência = impacto**

- Um evento potencial é aquele que pode ocorrer, mas não necessariamente vai acontecer. A cada evento é associada uma probabilidade de ocorrência, o que implica em certo grau de incerteza.
- A NOTA 4 descreve a equação que permite a determinação do nível de risco:
  - **RISCO = PROBABILIDADE x IMPACTO**
- A NOTA 5 esclarece um aspecto muito comum para o gerenciamento de risco – a incerteza. É difícil obter todas as informações sobre um evento, tais como fatos ou circunstâncias que levam à sua ocorrência, seu impacto ou sua probabilidade. No mundo real, busca-se obter a maior quantidade **possível** de informações confiáveis para tratar um dado risco, de forma a reduzir sua incerteza.
- O impacto de um risco pode ser positivo ou negativo. Dependendo da natureza desse impacto, o risco pode ser considerado uma oportunidade ou uma ameaça.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Figura 4.5 – Classificação do risco em relação à natureza de seu impacto
Fonte: FIAP (2018)

O mapeamento dos riscos em oportunidades e ameaças é o primeiro passo para o planejamento de ações futuras, em duas categorias básicas:

- Maximizar as oportunidades, visando explorar seus benefícios para a organização;
- Prevenir, mitigar ou remediar as ameaças, para evitá-las, monitorá-las ou reduzir seus impactos.

O Guia 73 também apresenta outras definições importantes para a gestão de riscos, destacadas a seguir:

**2.1 gestão de riscos**

Atividades coordenadas para dirigir e controlar uma organização no que se refere a **riscos** (1.1)

**2.1.1 estrutura de gestão de riscos**

Conjunto de componentes que fornecem os fundamentos e os arranjos organizacionais para a concepção, implementação, **monitoramento** (3.8.2.1), análise crítica e melhoria contínua da **gestão de riscos** (2.1) através de toda a organização.

**2.1.2. política de gestão de riscos**

Declaração das intenções e diretrizes gerais de uma organização relacionada à **gestão de riscos** (2.1)

**2.1.3 plano de gestão de riscos**

Esquema dentro da estrutura de **gestão de riscos** (2.1.1), que específica a abordagem, os componentes de gestão e os recursos a serem aplicados para gerenciar **riscos** (1.1)

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

### 3.1 processo de gestão de riscos

Aplicação sistemática de políticas, procedimentos e práticas de gestão para as atividades de comunicação, consulta, estabelecimento do contexto, e na identificação, análise, avaliação, tratamento, **monitoramento** (3.8.2.1) e análise crítica dos **riscos** (1.1)

A gestão de riscos é realizada a partir do estabelecimento de uma política organizacional com relação ao risco, que deve nortear o estabelecimento de uma estrutura para a gestão de riscos, dentro da qual se elabora um plano detalhado para a execução de um processo contínuo para gerenciamento de riscos (Figura Dinâmica da gestão de riscos).

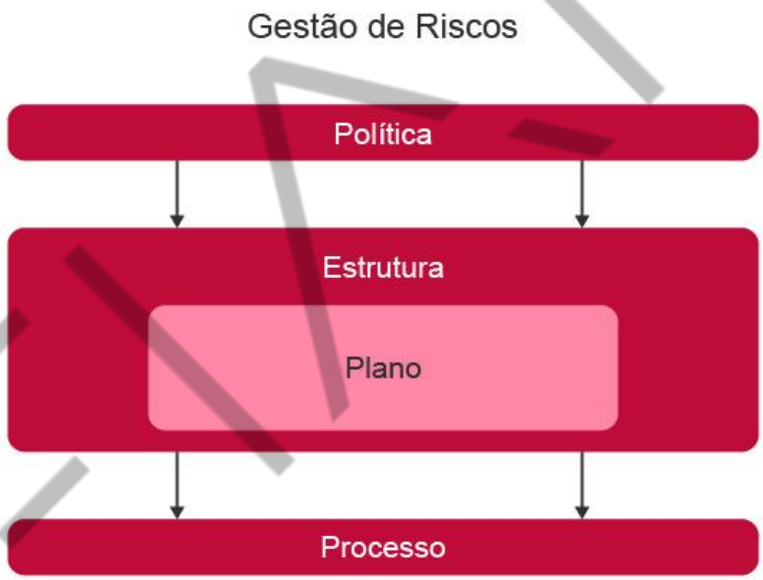


Figura 4.6 – Dinâmica da gestão de riscos
Fonte: FIAP (2018)

Outro conceito importante no gerenciamento de riscos é o de **controle**, que pode ser definido como uma medida para modificar o risco, no sentido de acompanhar as atividades planejadas para o risco e assegurar que sejam efetivas (ABNT, 2009a, p.7).

Na próxima seção, serão abordadas as razões pelas quais o gerenciamento de riscos é importante para as organizações.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

## 4.2 Benefícios – por que gerenciamento de riscos?

O dia 11 de setembro de 2001 ficou marcado na história como o dia em que ocorreu o maior ataque terrorista da história recente, quando os Estados Unidos foram surpreendidos por ativistas do grupo extremista Al-Qaeda.

Naquele dia, quatro aviões comerciais foram sequestrados pelos terroristas, sendo que dois deles colidiram com as Torres do *World Trade Center*, em Nova York. O impacto dos choques causou o desmoronamento dos edifícios. O terceiro avião foi lançado contra a sede do Pentágono e o quarto caiu em uma área desabitada na Pensilvânia. No total, aproximadamente três mil pessoas morreram em consequência dos ataques.

Além da comoção ocasionada pelo ataque, a cidade de São José dos Campos, no estado de São Paulo, sentiu outra consequência: no dia 1º de outubro de 2011, a Embraer demitiu 1.800 funcionários (EMBRAER, 2001).

Mas o que o ataque terrorista nos Estados Unidos tem a ver com essas demissões no Brasil?

A resposta a essa pergunta está associada à complexa rede de relacionamentos nas cadeias produtivas globais. A Embraer é uma das maiores empresas de aviação do mundo e a maior parte de seus negócios é feita no exterior, nos mercados globalizados da aviação civil, executiva e militar. Após os atentados de 11 de setembro, medidas urgentes foram tomadas no mundo todo para prevenir novos ataques terroristas, com várias restrições para embarque de passageiros e despacho de cargas nos aeroportos dos principais países do mundo. Além disso, houve uma redução imediata no número de passageiros dos voos comerciais, em decorrência do medo da população em relação a novos ataques. Como consequência, as companhias aéreas observaram queda significativa nas receitas e, diante de perspectivas negativas para curto e médio prazos, cancelaram seus pedidos de novas aeronaves. Dessa forma, a Embraer teve o cancelamento de 25 aeronaves em 2001, e uma redução de 75 aeronaves na programação de 2002. Diante do cenário adverso, a empresa decidiu demitir 14% de seu efetivo.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

O atentado de 11 de setembro de 2001 pode ser considerado um marco para a gestão de riscos. Ninguém, seja governo ou empresa, havia identificado o risco de um atentado terrorista de tais proporções.

A necessidade de uma gestão de risco mais efetiva aumentou no início da década de 2000, após a ocorrência de uma série de grandes fraudes contábeis (ASSI, 2012): Enron (EUA), em 2001; Arthur Andersen (EUA), em 2002; Worldcom (EUA), Xerox (EUA), e Tyco (EUA), em 2002; Parmalat (Itália), em 2003, como já vimos anteriormente.

O desafio para as organizações é comunicar de forma assertiva sua estratégia global e sua perspectiva de risco para todos os níveis da organização, de forma a apoiar a tomada de decisão baseada em gestão de risco. É importante considerar que, na prática, as organizações consideram os riscos muito mais como ameaças do que como oportunidades, ao estabelecer seus processos de gerenciamento de risco, atuando mais na prevenção e mitigação de riscos que podem causar prejuízos aos objetivos organizacionais (ASSI, 2017).

O Instituto Brasileiro de Governança Corporativa (IBGC) salienta que as organizações necessitam de um *framework* para gerenciamento de riscos, para lidarem de forma eficiente com a incerteza. A entidade apresenta três benefícios para a implantação de tal *framework* (IBGC, 2007):

1. Preservação e aumento do valor da organização, considerando a redução da probabilidade e/ou impacto de eventos de perda ou prejuízo, aliada à melhor percepção de *stakeholders* em relação ao nível de risco da organização.
2. Aumento da transparência, ao compartilhar os riscos e respectivos planos de resposta com os *stakeholders*.
3. Melhoria dos padrões de governança, ao alinhar o perfil de riscos da organização entre os *stakeholders*.

Na atualidade, as organizações empresariais estão sujeitas a várias categorias de risco e respectivas subáreas são detalhadas a seguir (IBGC, 2007; ASSI, 2012).

**Risco Operacional**

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Evento que pode causar perdas diretas e indiretas por ausência ou insuficiência de processos e controles internos que assegurem a eficácia das atividades técnico-operacionais. Dentre os subtipos de risco operacional, pode-se destacar:

- Risco de sobrecarga: associado à falta de capacidade da infraestrutura operacional (equipamentos, eletricidade, recursos computacionais, conectividade etc.).
- Risco de obsolescência: está relacionado ao aprisionamento tecnológico, ou seja, dependência de equipamentos e tecnologias antigas mais sujeitas a falhas e cuja manutenção tende a ser mais cara.
- Risco de presteza e confiabilidade: ligado ao tempo e à confiabilidade no recebimento, processamento, armazenamento e transmissão de informações.
- Risco de equipamento: susceptibilidade a falhas na infraestrutura operacional (predial, elétrica, mecânica, tecnologia da informação etc.).
- Risco de erro não intencional: associado aos equívocos, omissões, distração, despreparo ou negligência operacional dos colaboradores.
- Risco de fraude: relacionado à falta de conduta ética, divulgação de informações confidenciais ou não autorizadas, adulteração de controles e informações, desvio de valores, descumprimento intencional de normas e legislação.
- Risco de qualificação: decorrente da ausência da qualificação adequada dos colaboradores para o exercício de suas funções.
- Risco de produtos e serviços: derivado da venda e/ou entrega de produtos e serviços incompatíveis com as necessidades e demandas dos clientes.
- Risco de regulamentação: surge da alteração, inadequação ou inexistência de normas para controles internos e externos.
- Risco de sistêmico: associados a mudanças no ambiente operacional, alterações nos sistemas de informação e falta de homologação dos sistemas.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- Risco de concentração: derivam da dependência excessiva de determinados clientes, fornecedores ou mercados.
- Risco de imagem: eventos que podem impactar marcas por falhas de qualidade, atendimento e comunicação.
- Risco de catástrofe: associados aos desastres naturais (ou não) que podem impactar as operações, como incêndios, inundações, terremotos, furacões, explosões, colisões, acidentes etc.
- Risco de terceirização: ligado à transferência da gestão e/ou operação de processos internos para outras empresas.
- Risco de continuidade: diz respeito às situações de pane ou interrupção física ou lógica nas atividades da organização, tais como greves, protestos, sabotagens, ataques terroristas. O mapeamento deste tipo de risco é essencial para a elaboração de planos de contingência para garantir a operação dos negócios.

**Risco legal**

Evento de natureza jurídica que pode causar perdas ou contingências para a organização, em virtude de disputas legais originadas por transações comerciais, descumprimento de legislação vigente, novas leis, decisões judiciais etc.

**Risco contratual**

Evento associado a perdas por inadequação formal de contratos, interpretação errônea de cláusulas, ou não conformidade com legislação aplicável.

**Risco de conformidade**

Evento de impacto negativo causado pelo não cumprimento de normas e regulamentos, seja por interpretação incorreta ou violação intencional.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

**Risco político**

Evento ligado a mudanças no ambiente político do país, estado ou cidade, que podem influenciar a forma pela qual a organização realiza suas atividades.

**Risco econômico-financeiro**

Evento associado às atividades de caráter econômico ou financeiro na organização, podendo-se destacar os subtipos:

- Risco de liquidez: evento cujo impacto está associado à falta de capacidade da organização de honrar seus compromissos financeiros de curto, médio e longo prazo, seja em cenários de normalidade ou crise econômica.
- Risco de taxa: decorre da diferença entre as taxas de juros praticadas na captação e aplicação de recursos da organização.
- Risco cambial: está relacionado a mudanças adversas nas taxas de câmbio, que podem impactar os preços de títulos indexados em moeda estrangeira, de ativos internacionais negociados em moeda estrangeira ou descompasso entre carteiras indexadas em outras moedas.
- Risco de derivativos e hedge: ligado às práticas e políticas para uso de instrumentos derivativos.
- Risco de preços no mercado: associado à variação dos preços praticados pelos fornecedores ou concorrentes, com impacto potencial sobre o retorno de investimentos.
- Risco de crédito: requer atenção das organizações, pois pode impactar o seu fluxo financeiro. Inclui alguns subtipos de risco, tais como inadimplência, degradação de crédito, garantia real, concentração de fontes de financiamento, dentre outros.
- Risco país: está relacionado à avaliação geral de um país, que considera a sua estabilidade (ou instabilidade) econômica, social e política.

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

**Risco contábil**

Evento relacionado às práticas contábeis adotadas pela empresa e sua conformidade com os princípios aceitos pelo mercado e com as regulamentações aplicáveis à atividade da organização. Exemplos: erros/fraudes contábeis que podem ocasionar sanções dos órgãos reguladores, erro de valorização de carteira, erro de comunicação e discrepâncias no processamento contábil.

**Risco de mercado**

É definido como o potencial de resultado negativo, devido a mudanças nos preços ou parâmetros de mercado. Os principais preços / parâmetros são preços de ações, curvas de juros, taxas de câmbio, volatilidades e correlações.

## 4.3 Como gerenciar riscos – o padrão ISO 31000

A ISO considera que todas as atividades realizadas por uma organização, em quaisquer de seus níveis hierárquicos, estão envolvidas com riscos. Por isso, a entidade desenvolveu um processo sistemático e genérico para gestão de riscos, que pode ser adaptado por organizações de qualquer porte ou segmento econômico. Foi criado, assim, o padrão ISO 31000 (ISO, 2009b)

Se uma organização adota o padrão ISO 31000, ela se torna capaz de identificar, analisar, avaliar e tratar os riscos inerentes ao seu negócio de forma sistêmica, para atender suas necessidades e alcançar seus objetivos. Isso inclui atividades de comunicação entre todos os *stakeholders* e o contínuo monitoramento dos riscos, para assegurar um tratamento adequado de cada risco ao longo do tempo.

O padrão ISO 31000 está organizado em três grandes partes, mostradas a seguir (Figura Relacionamentos entre princípios, estrutura e processo da ISO 31000):

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

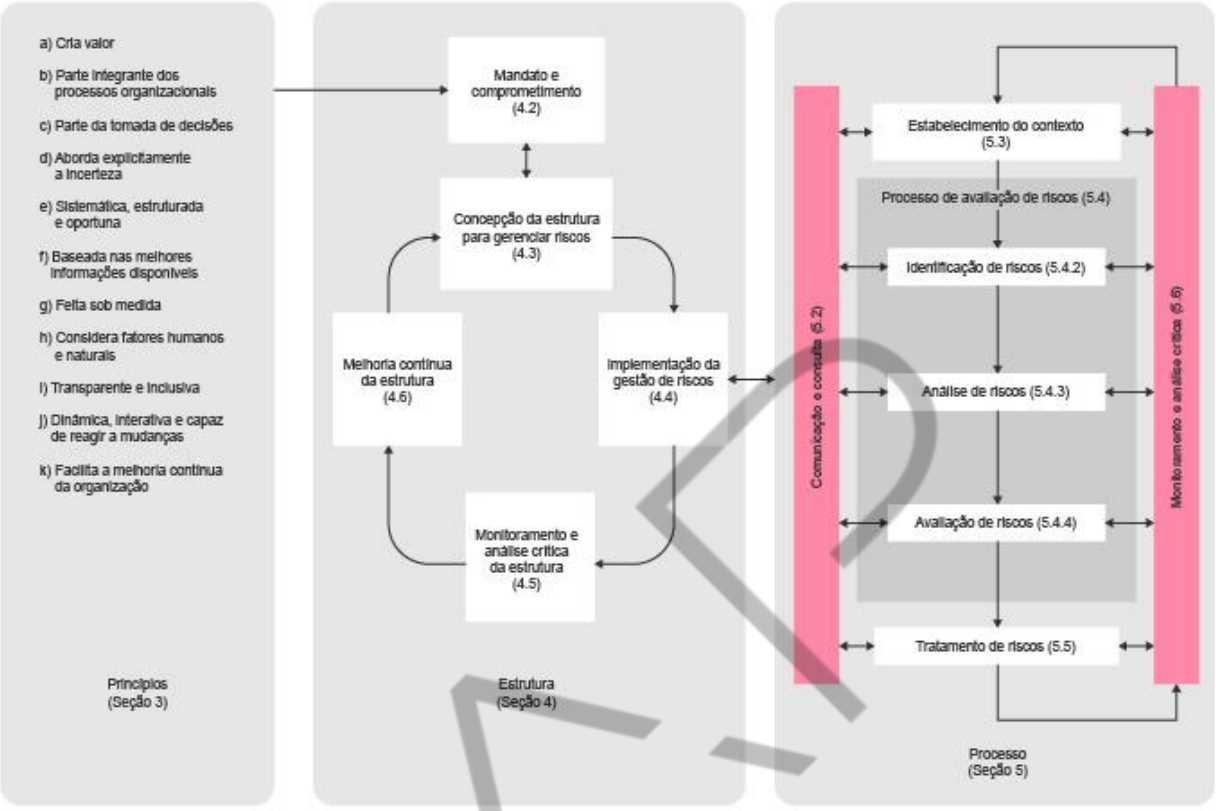


Figura 4.7 – Relacionamentos entre princípios, estrutura e processo da ISO 31000
Fonte: ABNT (2009b, p. vii), adaptado por FIAP (2018)

Cada uma das partes será detalhada nas próximas seções.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

### 4.3.1 Princípios da gestão de riscos

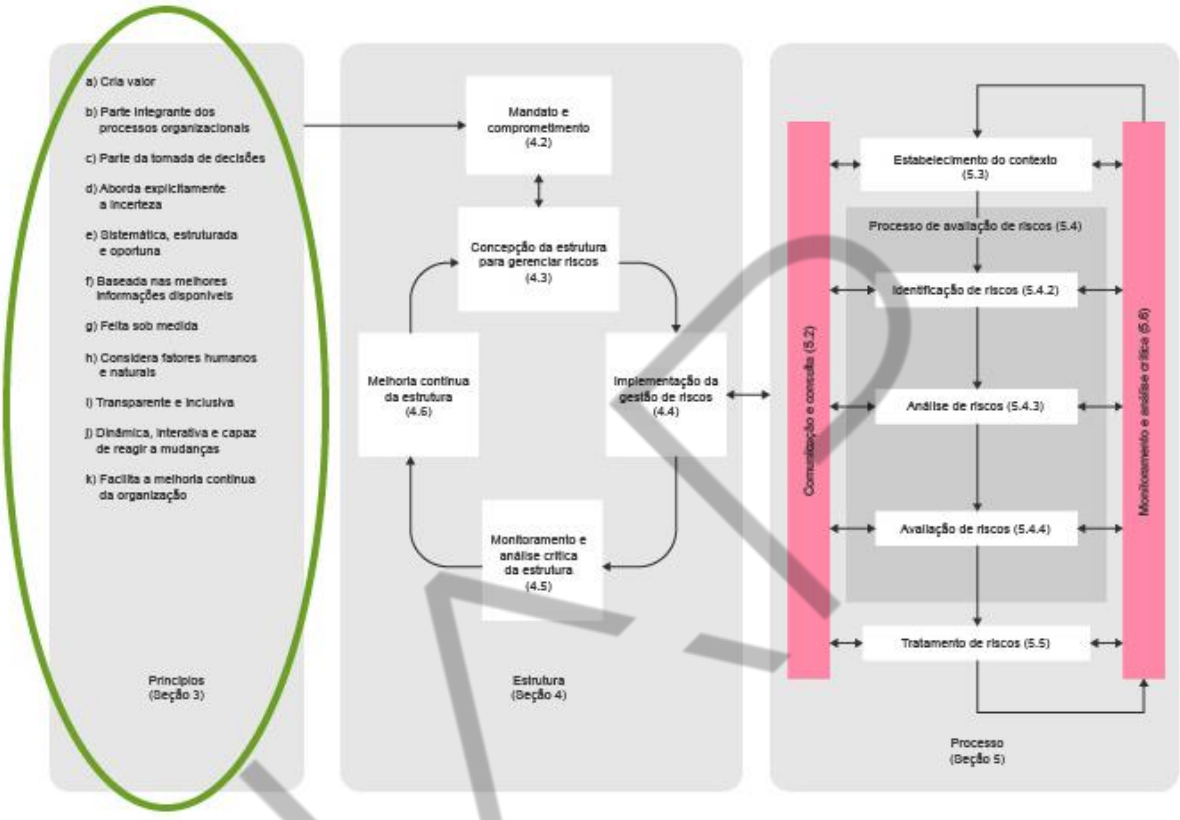


Figura 4.8 – Relacionamentos entre princípios, estrutura e processo da ISO 31000.
Fonte: ABNT (2009b, p. vii), adaptado por FIAP (2018)

Para garantir a eficácia da gestão de riscos, o padrão ISO 31000 estabelece alguns princípios a serem atendidos por todos os níveis da organização:

a) Criação e proteção de valor: a gestão de riscos traz uma contribuição importante para o alcance dos objetivos organizacionais e melhoria do desempenho do negócio.

b) Integração com todos os processos organizacionais: a gestão de riscos não pode ser autônoma, mas deve fazer parte das responsabilidades de todos os colaboradores e, inclusive, abranger o planejamento estratégico, a gestão de projetos, mudança e operações.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

c) Parte da tomada de decisão: a gestão de riscos habilita os decisores a realizar escolhas conscientes, priorizar ações e trabalhar com cenários alternativos.

d) Abordagem explícita da incerteza: a gestão de riscos considera todas as incertezas do negócio, suas naturezas e tratamento adequado.

e) Abordagem sistemática, estruturada e oportuna: para obtenção de consistência, comparabilidade e confiabilidade nos resultados da gestão de riscos.

f) Uso da melhor informação disponível: a gestão de riscos deve se basear em dados históricos, experiências, *feedbacks* de *stakeholders*, observações, previsões e opiniões de especialistas, considerando-se suas limitações e a possibilidade de divergências.

g) Sob medida: a gestão de riscos precisa estar alinhada com os contextos interno e externo da organização e com seu perfil de risco.

h) Fatores humanos e culturais: a gestão de riscos considera que capacidades, percepções e intenções de pessoas internas e externas à organização podem facilitar ou não o processo.

i) Transparência e inclusão: a gestão de riscos necessita do envolvimento apropriado e oportuno de todos os *stakeholders* para garantir que suas expectativas e opiniões sejam levadas em conta no tratamento dos riscos.

j) Dinamismo, interação e capacidade de reação a mudanças: a gestão de riscos deve ser contínua, repetitiva e capaz de perceber mudanças internas e externas, para identificar novos riscos, modificar o tratamento de riscos existentes e remover riscos que não podem mais acontecer.

k) Melhoria contínua da organização: à medida que amadurece, a gestão de riscos suporta a melhoria de outros processos da organização.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

### 4.3.2 Estrutura para gestão de riscos

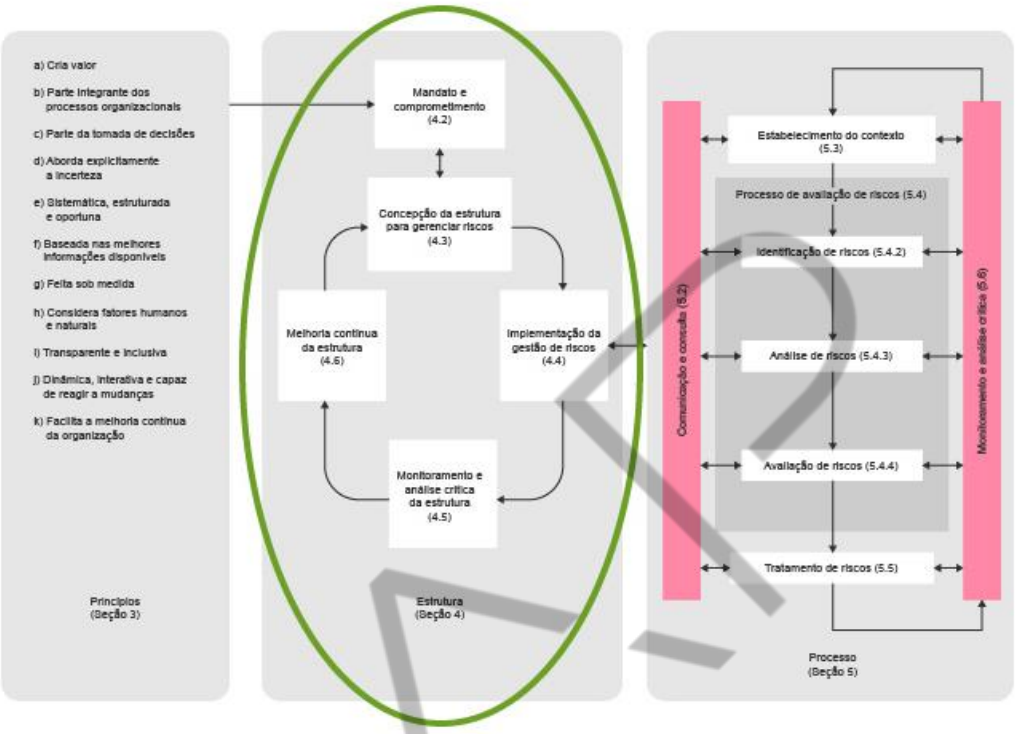


Figura 4.9 – Relacionamentos entre princípios, estrutura e processo da ISO 31000
Fonte: ABNT (2009b, p. vii), adaptado por FIAP (2018)

A estrutura é uma parte crítica para o sucesso da gestão de riscos, pois ela deve garantir os recursos e arranjos necessários para a boa execução do processo. Ela deve contar com cinco elementos (Figura Componentes da estrutura de gestão de riscos do padrão ISO 31000), que serão explicados a seguir.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

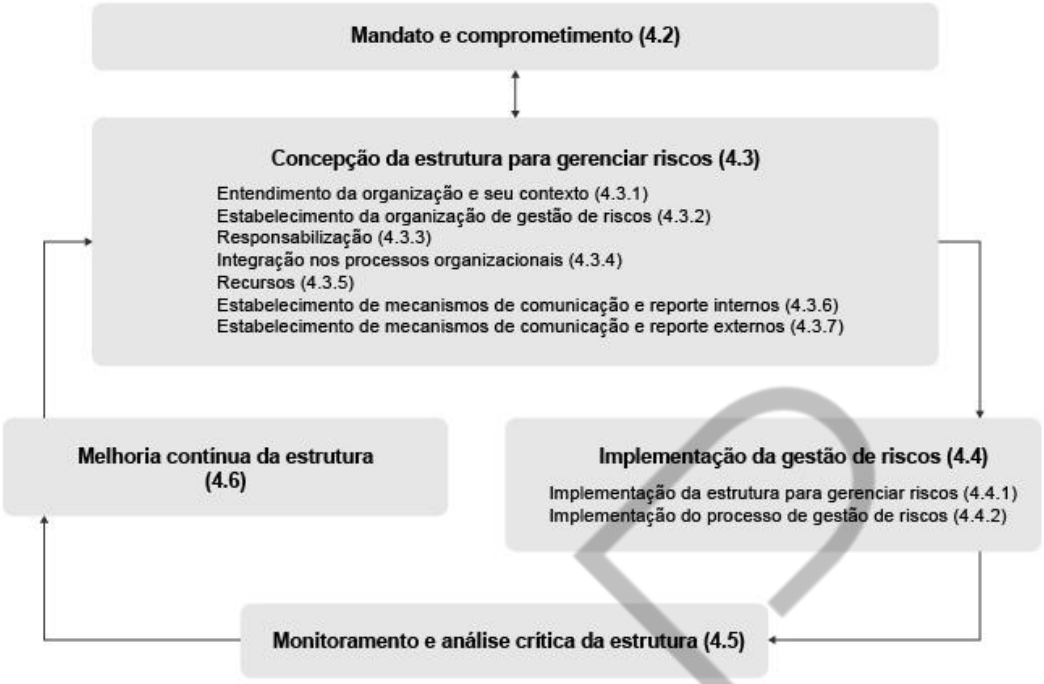


Figura 4.10 – Componentes da estrutura de gestão de riscos do padrão ISO 31000
Fonte: ABNT (2009b, p. 9)

O primeiro componente, Mandato e comprometimento, diz respeito ao compromisso da alta administração da organização em garantir:

- Criação e aprovação de uma política para a gestão de riscos;
- Alinhamento entre a cultura da organização e a política de gestão de riscos;
- Definição de indicadores de desempenho de gestão de riscos alinhados aos indicadores de desempenho do negócio;
- Alinhamento dos objetivos da gestão de riscos com os objetivos e estratégias da organização;
- Conformidade legal e regulatória;
- Atribuição de responsabilidades sobre a gestão de riscos nos níveis organizacionais;
- Alocação dos recursos necessários para a gestão de riscos;
- Comunicação dos benefícios da gestão de riscos aos *stakeholders*;
- Melhoria contínua da estrutura de gestão de riscos.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

O segundo componente, Concepção da estrutura para gerenciar riscos, está relacionado ao planejamento detalhado da estrutura para a gestão de riscos e engloba as seguintes atividades macro:

- Entendimento da organização e seu contexto: envolve a avaliação e a compreensão dos ambientes interno e externo em sentido amplo, com o mapeamento dos stakeholders, da estrutura organizacional, de aspectos culturais e políticos, do modelo de governança e tomada de decisão, das capacidades da organização (pessoas, processos e tecnologia), etc.
- Estabelecimento da política de gestão de riscos: inclui a definição clara dos objetivos, das responsabilidades, dos recursos necessários, dos mecanismos de monitoração de desempenho, do tratamento de conflitos e da melhoria contínua da gestão de riscos.
- Responsabilização: identificar as pessoas da organização que terão papéis no processo de gestão de riscos, e atribuir a elas a responsabilidade e a devida autoridade para o exercício efetivo desse papel.
- Integração nos processos organizacionais: assegurar que o processo de gestão de riscos seja incorporado à rotina e integrado aos demais processos da organização, especialmente aos relacionados com o planejamento estratégico e com a gestão de mudanças.
- Recursos: identificação dos recursos necessários ao processo de gestão de riscos, incluindo pessoas e respectivas competências requeridas, métodos, ferramentas, sistemas de informação, treinamentos etc.
- Estabelecimento de mecanismos de comunicação e reporte internos: definição dos conteúdos, formatos, meios e frequência das comunicações para os stakeholders internos, visando à divulgação oportuna e pontual de informações derivadas da gestão de riscos, e o apoio e incentivo à responsabilização e propriedade dos riscos.
- Estabelecimento de mecanismos de comunicação e reporte externos: plano de comunicação com stakeholders externos, visando seu engajamento, atendimento de requisitos legais, regulatórios e de governança, construção

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

e manutenção de uma relação de confiança, e informação em eventos de crise ou contingência.

O terceiro componente, Implementação da gestão de riscos, visa materializar o uso da política e do processo de gestão de riscos na organização, por meio de treinamento, da alocação efetiva de recursos e da execução do plano de riscos.

O quarto componente, Monitoramento e análise crítica da estrutura, é o responsável pela medição e análise dos indicadores do processo de gestão de risco e pela identificação de oportunidades de melhoria.

O quinto e último componente, Melhoria contínua da estrutura, é o responsável pela elaboração de um plano de melhoria para a política, plano e estrutura da gestão de riscos, a partir das oportunidades identificadas pelo monitoramento e análise crítica da estrutura.

### 4.3.3 Processo para gestão de riscos

O processo de gestão de riscos especificado pela ISO 31000 deve ser incorporado na cultura, nas práticas e nos processos de gestão da organização, bem como adaptado aos processos de negócio.

O processo compreende cinco fases (Figura Processo de Gestão de Risco do padrão ISO 31000).

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

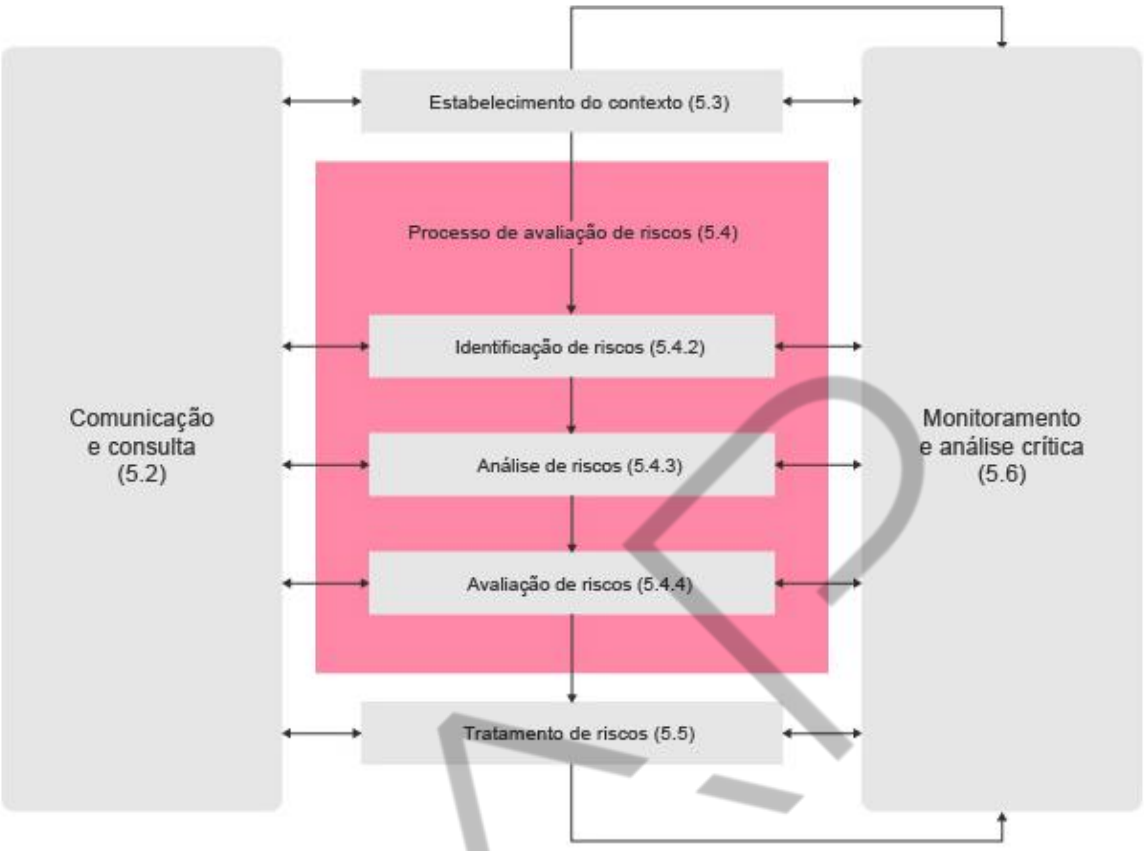


Figura 4.11 – Processo de Gestão de Risco do padrão ISO 31000
Fonte: ABNT (2009b, p. 14), adaptado por FIAP (2018)

As fases do processo serão descritas nas próximas seções.

### 4.3.4 Estabelecimento do contexto

Esta fase é responsável pela articulação dos objetivos e pelo estabelecimento dos parâmetros e critérios detalhados a serem usados na prática da gestão de riscos.

Ela envolve as seguintes atividades:

- Definição das metas e objetivos das atividades de gestão de riscos;
- Definição do escopo, profundidade e amplitude das atividades de gestão de risco;
- Definição da atividade, processo, função, projeto, produto, serviço ou ativo, incluindo seus respectivos tempos e localização, a serem incluídos na gestão de risco;

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- Definição dos métodos para avaliação de riscos;
- Definição da forma de avaliação do desempenho e eficácia na gestão dos riscos; e
- Identificação e especificação das decisões a serem tomadas.

O contexto é que pode assegurar que a abordagem prática da gestão de risco seja apropriada e efetiva para a organização.

### 4.3.5 Análise e avaliação de riscos

Esta fase é central no processo e engloba três etapas importantes para a identificação, a análise, e a própria avaliação de riscos.

A primeira etapa é a identificação de riscos e tem como objetivo elaborar uma lista de riscos abrangente e detalhada. Cada risco deve ser devidamente registrado, com as seguintes informações:

- Descrição do evento;
- Possíveis causas e circunstâncias de ocorrência; e
- Consequências potenciais / áreas de impacto.

Todas as possíveis fontes de risco devem ser mapeadas pela organização, mesmo aquelas que não estejam sob seu controle. Outro ponto importante é o exame de reações em cadeia provocadas por efeitos específicos. Como exemplo de uma reação em cadeia, temos a demissão dos funcionários da Embraer após o 11 de setembro.

Para identificação de riscos, podem ser usadas várias técnicas, como o uso de *checklists*, bases de lições aprendidas, *brainstorming*, obtenção da opinião de especialistas, entrevistas, reuniões etc. É importante que o máximo de pessoas apropriadas seja envolvido nesta fase, incluindo pessoas de fora da organização sempre que necessário, pois alguns riscos podem estar associados a fornecedores, clientes e parceiros de negócios. Quanto maior o número de riscos identificados e maior a quantidade de detalhes sobre eles, melhor tende a ser o resultado desta etapa.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

A segunda etapa é a análise de riscos, cujo objetivo é compreender cada risco identificado, a partir da apreciação de suas causas, consequências e probabilidades.

Nesta etapa, deve-se empregar uma escala padronizada, seja ela numérica ou qualitativa (com atributos de classificação do tipo baixo, médio e alto), para se determinar os níveis de probabilidade e de impacto de cada evento identificado, e em seguida combiná-los para ver o nível de risco.

Uma ferramenta comum para esta etapa é o uso de mapas de risco (Figura Mapa de risco):

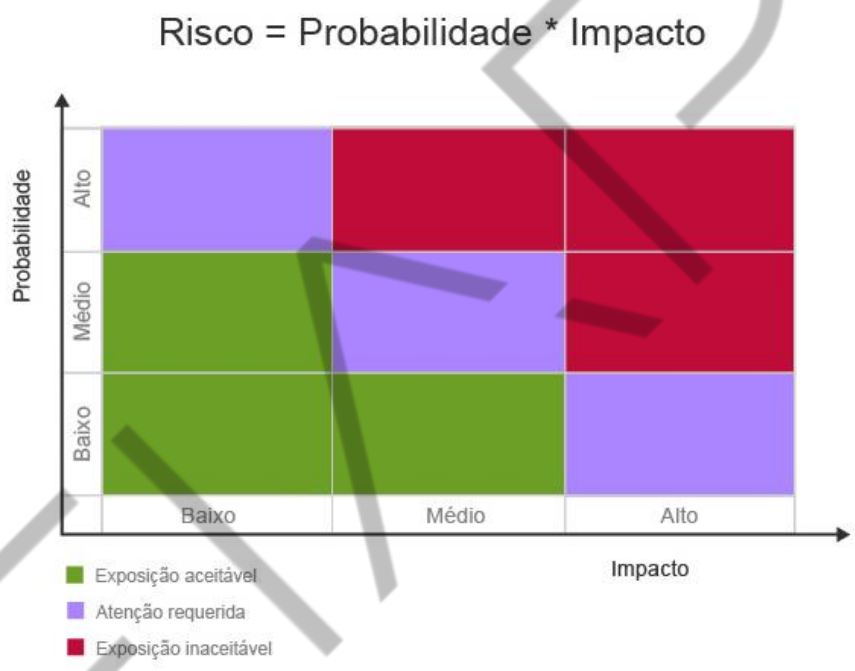


Figura 4.12 – Mapa de risco
Fonte: FIAP (2020)

Basicamente, o mapa de risco trabalha com a combinação de probabilidade X impacto de um risco e pode assumir diversas escalas dentro dos dois eixos de acordo com a política da organização que o aplica. Por exemplo, se um dado risco apresentar alta probabilidade de ocorrência e alto nível de impacto, sua severidade será crítica.

Em geral, o resultado da etapa de análise de risco é a lista de riscos classificada.

A terceira e última etapa é a de avaliação de riscos, cujo objetivo é definir quais riscos precisam ser priorizados para tratamento.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Basicamente, avalia-se o nível de risco e demais informações, tomando-se como base os parâmetros e critérios de risco estabelecidos pela organização, tais como o nível de tolerância a risco, requisitos legais, regulatórios ou de controles internos.

Ao final da etapa, uma lista com riscos priorizados é produzida para que a próxima fase do processo seja realizada.

### 4.3.6 Tratamento de riscos

Esta fase diz respeito às decisões sobre o tratamento a ser dado para cada risco identificado, analisado e avaliado. Normalmente, as opções de tratamento para riscos envolvem as seguintes ações:

- Evitar o risco ao não iniciar ou descontinuar uma atividade que pode materializá-lo;
- Tomar ou aumentar o risco, quando se trata de oportunidade;
- Remover a fonte de risco;
- Alterar a probabilidade de ocorrência;
- Alterar as consequências (reduzir ou modificar o impacto); e
- Compartilhar ou transferir o risco com outras partes.

Os três últimos itens são possíveis por meio da implementação de controles.

Se as opções de tratamento afetam vários *stakeholders*, eles devem ser envolvidos na decisão. É importante considerar que determinada ação de tratamento pode introduzir novos riscos, que também precisam ser avaliados e monitorados.

Outra atividade desta fase é a elaboração do plano para tratamento de riscos, que deve conter as seguintes informações:

- Racional das ações de tratamento – porque foram escolhidas;
- Responsáveis pela aprovação do plano;
- Responsáveis pela implementação do plano;

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- Ações a serem executadas;
- Os recursos necessários, incluindo contingências;
- Medidas de desempenho e restrições;
- Requisitos para apresentação de informação e monitoramento; e
- Cronograma e programação.

É importante que os planos de tratamento sejam integrados aos demais processos da organização conforme necessidade. Por exemplo, pode ser necessário ter aprovação financeira do plano e sua execução pode estar sujeita ao processo de gestão de mudança.

Os planos precisam estar claros a todos os envolvidos, e sua execução pode ser invocada pela atividade de monitoramento e análise crítica, que será explicada a seguir.

### 4.3.7 Monitoramento e análise crítica

Esta fase assegura a verificação regular dos riscos identificados, analisados e avaliados, com a finalidade de manter o registro de riscos atualizado e, especialmente, de acionar a execução do plano de tratamento de risco sempre que necessário. Por isso, ela deve ocorrer de forma concomitante com as outras fases.

Além disso, as atividades de monitoramento devem garantir que:

- Os controles sejam eficazes e eficientes, tanto para projetos como operações regulares;
- Informação adicional para a avaliação de riscos seja obtida;
- Eventos, mudanças, tendências, sucessos e fracassos sejam analisados e as lições aprendidas, registradas;
- Mudanças nos contextos interno e externo sejam detectadas, tanto nos critérios de risco como nas condições dos riscos, porque podem ocasionar nova análise, avaliação e tratamento; e
- Novos riscos sejam detectados e sua identificação disparada.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

### 4.3.8 Comunicação e consulta

Esta fase deve acontecer em paralelo às demais fases do processo de gestão de risco, porque a comunicação é contínua. Por exemplo, a lista de riscos identificados deve ser comunicada a todos os *stakeholders* relevantes, assim como as listas de riscos analisados e priorizados, da mesma forma que os planos de tratamento de riscos.

Além disso, cabe à comunicação garantir que todos os *stakeholders* tenham o conhecimento apropriado do processo de gestão de riscos, bem como dos parâmetros e definições de risco adotados pela organização.

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

# REFERÊNCIAS

ABNT. **ABNT ISO GUIA 73: gestão de riscos – vocabulário**. São Paulo: ABNT, 2009a.

ABNT. **ABNT NBR ISO 31000: gestão de riscos – princípios e diretrizes**. São Paulo: ABNT, 2009b.

ASSI, M. **Gestão de riscos com controles internos**: ferramentas, certificações e métodos para garantir a eficiência dos negócios. São Paulo: Saint Paul, 2012.

ASSI, M. **Governança, Riscos e Compliance**. São Paulo: Saint Paul Editora, 2017.

BARALDI, Paulo. **Riscos Estratégicos e Desempenho**. São Paulo: IBGC, 2018.

BERNSTEIN, P. L. **Desafio aos deuses**: a fascinante história do risco. 16. ed. Rio de Janeiro: Campus, 1997.

EMBRAER. **Embraer anuncia medidas para manter a sua posição de liderança no mercado mundial de aviação comercial**. 2001. Disponível em: <http://www2.embraer.com/pt-BR/ImprensaEventos/Press-releases/noticias/Paginas/ANUNCIA-MEDIDAS-PARA-MANTER-A-SUA-POSICAO-DE-LIDERANCA-NO-MERCADO-MUNDIAL-DE-AVIACAO-COMERCIAL.aspx>. Acesso em: 28 set. 2001.

IBGC. **Guia de orientação para o gerenciamento de riscos corporativos**. São Paulo: IBGC, 2007.

SAXON, Wolfgang. Arthur Rudolph, 89, developer of rocket in first Apollo flight. **The New York Times**. Nova York, 03 jan. 1996. Disponível em: <http://www.nytimes.com/1996/01/03/us/arthur-rudolph-89-developer-of-rocket-in-first-apollo-flight.html>. Acesso em: 12 jun. 2020.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com